

SOC 2 TYPE II

READINESS ASSESSMENT

Crestline Technology Partners

ASSESSMENT DETAILS

Framework:	AICPA Trust Services Criteria 2017 (2022 POF)
Scope:	CC6 CC7 CC9 — 22 Controls
Assessment Date:	June 2026
Prepared By:	Maximilian Rivera, GRC Analyst
Status:	CONFIDENTIAL — FOR PORTFOLIO USE ONLY

TABLE OF CONTENTS

Section 1	Executive Summary	3
Section 2	Control Assessment Table	4
Section 3	Findings Summary	9
Section 4	Management Letter	11
Section 5	12-Month Remediation Roadmap	12

SECTION 1: EXECUTIVE SUMMARY

To: The CEO and CFO of Crestline Technology Partners

Re: SOC 2 Type II Readiness Assessment Results

What Is SOC 2 and Why Does It Matter Right Now?

SOC 2 is a security audit standard developed by the American Institute of Certified Public Accountants (AICPA). It was built specifically for technology companies that store, process, or transmit data on behalf of their clients. When an enterprise company requires SOC 2 compliance from a vendor, they are asking for independent, third-party verification that the vendor's security controls actually work — not just that a policy document says they should.

There are two types. SOC 2 Type I is a point-in-time assessment: it confirms that controls are designed correctly as of a specific date. SOC 2 Type II is harder and more credible: it requires that those controls operate effectively over an extended observation period, typically six to twelve months. Your enterprise client is requiring Type II, which means the clock on that observation period needs to start as soon as possible.

The cost of not completing SOC 2 in this case is straightforward: you do not close the enterprise contract. The cost of completing it with significant deficiencies is also real — a qualified audit opinion or audit suspension can damage the relationship before it starts. The path forward is to fix the gaps first, then start the audit clock.

What We Assessed

This readiness assessment evaluated 22 controls across three categories of the AICPA Trust Services Criteria: CC6 (Logical and Physical Access), CC7 (System Operations and Incident Management), and CC9 (Risk Mitigation and Vendor Management). These categories were selected because they represent the areas most likely to surface material findings during a formal audit of a SaaS company at Crestline's stage of maturity.

The assessment was conducted through documentation review, stakeholder interviews, system configuration inspection, and access log analysis. Findings were rated on both compliance status (Compliant, Partial, Non-Compliant) and risk severity (Critical, High, Medium, Low) based on the likelihood and potential impact of exploitation.

What We Found

FINDING TYPE	COUNT	EXAMPLES
Critical	3	Orphaned accounts with active payroll access; No MFA on privileged accounts; No access termination process
High	6	No incident response plan; Direct-to-production code deployments; Vendor contracts missing security terms
Medium	5	No BCP/DRP; No risk register; No security awareness training program
Low / Compliant	8	Base-level AWS encryption; HTTPS/TLS in use; AWS CloudTrail logging enabled

The Bottom Line

Crestline is not ready for a SOC 2 Type II audit today. That is the honest assessment. The critical findings — particularly the orphaned accounts with active access to payroll systems, the absence of multi-factor authentication on privileged

accounts, and the complete lack of incident response planning — are the kinds of issues that cause a formal auditor to pause the engagement until they are resolved.

The good news is that none of these findings are structural. They are operational gaps that can be closed systematically over the next 90 days. Crestline has the foundational infrastructure — AWS with encryption enabled, HTTPS in use, version-controlled code — that makes building on top of these findings achievable without starting over.

The recommendation is a phased remediation approach: fix the critical and high findings first (the ones that would stop an audit cold), then build the program infrastructure, then start the formal audit observation period. A realistic timeline to audit readiness is 12 months from today, with a formal SOC 2 Type II report achievable within that window if remediation begins immediately.

SECTION 2: CONTROL ASSESSMENT TABLE

The table below presents the full assessment of 22 controls evaluated against the AICPA Trust Services Criteria (2017, with 2022 points of focus). Controls are grouped by category. Gap ratings and risk ratings reflect the state of controls at time of assessment (June 2026).

CC6 — Logical and Physical Access Controls

CC6.1 — Logical Access Security

Gap: **Non-Compliant** Risk: **Critical** Timeline: **30 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
Crestline must ensure that only authorized individuals can access its systems, applications, and data. This means requiring strong authentication — including multi-factor authentication (MFA) for anyone with elevated privileges — and enforcing the principle of least privilege: people get access to exactly what their job requires, nothing more.	The IT manager and two senior engineers access the production database and payroll system using only username and password combinations. No MFA is enforced. No conditional access policies exist. No time-based or IP-based restrictions are in place. Privileged credentials are stored informally.	Immediately enroll all privileged accounts (minimum: IT manager, senior engineers, any account with database or payroll system write access) in MFA via an authenticator app (Duo, Okta, or Google Authenticator). Configure conditional access policies requiring MFA for all production system logins regardless of network location. Draft and execute a Privileged Access Policy that defines: (1) who qualifies as a privileged user, (2) MFA requirements, (3) session timeout standards (15-min inactivity), and (4) prohibition on shared credentials. Owner: IT Manager. Review: CISO/VP Eng quarterly.

CC6.2 — User Access Provisioning

Gap: **Non-Compliant** Risk: **High** Timeline: **30 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
When someone joins Crestline or changes roles, their system access should be granted through a formal, documented process tied to their job function. Access should require manager approval and should be provisioned through a tracked workflow — not handed out informally.	No formal onboarding access provisioning workflow exists. Access is granted informally via Slack message or verbal request to the IT manager. No approval records are maintained. New hire access is not consistently aligned to job role, and there is no documented access request or authorization form.	Implement a formal Access Request Form (paper or ITSM ticket) capturing: requester name, system requested, business justification, and manager approval signature. Store completed forms in a designated HR/IT shared drive. Create an Access Provisioning SOP covering new hire, role change, and offboarding workflows. ITSM tools like Jira Service Management or even a structured Google Form can satisfy this at Crestline's current scale. Owner: IT Manager with HR co-ownership for new hire workflow.

CC6.3 — User Access Review and TerminationGap: **Non-Compliant** Risk: **Critical** Timeline: **30 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
Periodically, Crestline should review who has access to what and confirm that it still makes sense. When employees leave, their access should be revoked immediately. This control is about making sure access doesn't outlive the reason it was granted.	FINDING: During access log review, 7 active user accounts were identified belonging to former employees who departed 8 to 18 months ago. Three of these accounts retain read/write access to the payroll processing system. No formal access review has been conducted since the company's founding. There is no offboarding checklist that includes system deprovisioning.	Immediate action: Audit all active accounts across production systems this week. Disable all accounts belonging to former employees — do not delete yet, preserve for 90-day forensic hold. Implement a quarterly access review process where system owners certify that each active account is still appropriate for its current access level. Build an offboarding checklist that includes same-day account deprovisioning as a required step, co-signed by HR and IT. Document this in an Access Management Policy. Owner: IT Manager; HR signs off on offboarding completions.

CC6.4 — Physical Access to Information AssetsGap: **Partial** Risk: **Medium** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
Crestline must control who can physically access locations where its systems and sensitive data are housed — including its offices, server closets, and any co-location or data center facilities.	Crestline operates in a leased office space with keycard access to the main entrance. A server closet exists on-premises housing networking equipment. The closet is locked but the key hangs on a hook in the IT manager's office and is not access-logged. AWS hosts production workloads (SOC 2 covered). No visitor log is maintained for the office.	Secure the server closet with a combination lock or keypad and log all access entries in a physical logbook or digital access system. Maintain a visitor sign-in log at the front desk. Document a Physical Security Policy that covers: authorized access to sensitive areas, visitor escort requirements, and media disposal procedures. Review AWS shared responsibility model documentation and include it as an exhibit in the audit package.

CC6.5 — Logical Access RemovalGap: **Non-Compliant** Risk: **Critical** Timeline: **30 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
When someone's relationship with Crestline ends — whether they resign, are terminated, or change roles — their access to systems should be removed promptly and documented. Delayed deprovisioning is one of the most common audit findings in any security review.	No documented deprovisioning procedure exists. Offboarding is handled informally between HR and the IT manager. Timing of access removal is inconsistent and not tracked. The 7 orphaned accounts identified under CC6.3 directly evidence failure of this control.	Create a formal Offboarding Checklist that requires IT sign-off on account deprovisioning before HR closes the separation paperwork. Target: access revoked within 4 business hours of separation for voluntary terminations, immediately upon notification for involuntary terminations. Track completion in a termination log. This should be codified in the Access Management Policy developed under CC6.2 and CC6.3. Owner: IT Manager; HR triggers the workflow.

CC6.6 — Logical Access Restrictions — External ConnectionsGap: **Partial** Risk: **High** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
Any external access to Crestline's environment — remote workers, contractors, third-party support — should go through a controlled, authenticated pathway. Open or unmonitored remote access is a significant attack surface.	Remote access to production systems is conducted via direct SSH connections and RDP sessions without VPN enforcement. Contractor access is granted on an ad-hoc basis without formal documentation. No network segmentation between corporate and production environments exists.	Require all remote and contractor access to route through a VPN with MFA (Tailscale, Cloudflare Access, or OpenVPN are cost-effective options). Implement network segmentation to separate production from corporate traffic. Require formal contractor access agreements prior to granting any access. Log all remote sessions. Owner: IT Manager.

CC6.7 — Transmission and Movement of InformationGap: **Partial** Risk: **Medium** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Data moving between Crestline's systems and its clients — especially payroll and HR data — must be encrypted in transit. Unencrypted data transmission creates exposure to interception and is a hard audit failure.	API communications use HTTPS/TLS 1.2+. Internal database connections use encrypted channels. However, no formal data classification policy exists, and some internal file transfers between departments occur over email without encryption controls on attachments containing client data.	Establish a Data Classification Policy that categorizes data types (Confidential, Internal, Public) and defines handling requirements for each. Prohibit transmission of Confidential data via unencrypted email; enforce use of encrypted file-sharing tools (Google Drive with sharing restrictions, or a dedicated secure transfer solution). Verify TLS version standards across all endpoints and document the configuration. Owner: IT Manager.

CC6.8 — Malware and Unauthorized Software ControlsGap: **Partial** Risk: **High** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Crestline needs to protect its systems from malware, ransomware, and unauthorized software that could compromise client data or system integrity. This includes endpoint protection and controls over what software employees can install.	Endpoint detection and response (EDR) software is not consistently deployed across all workstations. Some employee laptops use Windows Defender only. No mobile device management (MDM) policy governs personal devices used for work access. Software installation is unrestricted on employee workstations.	Deploy a unified EDR solution (CrowdStrike, SentinelOne, or Microsoft Defender for Endpoint) across all company-managed devices. Implement MDM (Jamf, Intune, or Kandji) with a BYOD policy prohibiting access to production systems from unmanaged devices. Restrict software installation privileges on employee workstations. Document in an Endpoint Security Policy. Owner: IT Manager; all-company rollout required.

CC6.9 — Data Encryption at RestGap: **Partial** Risk: **Medium** Timeline: **30 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Client payroll and HR data stored in Crestline's systems must be encrypted at rest. If a storage medium is lost or stolen, encryption prevents exposure of sensitive data.	AWS S3 buckets used for data storage have server-side encryption enabled (AES-256 via SSE-S3). RDS database instances have encryption at rest enabled. However, encryption key management is not formally documented, and two S3 buckets were identified without default encryption enforced at the bucket level.	Enable default encryption on all S3 buckets and enforce via AWS S3 bucket policies that block unencrypted PUT operations. Migrate to AWS KMS with customer-managed keys (CMKs) for production RDS and S3 data. Document key rotation schedule (annual minimum). Create an Encryption Policy covering data at rest and in transit standards. Owner: IT Manager; AWS environment review can be completed quickly.

CC6.10 — Inventory and Classification of Information AssetsGap: **Non-Compliant** Risk: **Medium** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Crestline should maintain a current inventory of the systems, applications, and data repositories that hold client information. You can't protect what you can't see, and auditors will ask for it.	No formal asset inventory exists. The IT manager maintains an informal list of hardware in a personal spreadsheet, but it has not been updated in approximately 8 months. No software asset inventory or data flow diagram documenting where client data resides has been produced.	Build a comprehensive Asset Inventory covering: hardware (all company-owned and approved personal devices), software (all SaaS tools and internal applications), and data assets (where client data is stored, processed, and transmitted). Create a data flow diagram showing client data ingestion through processing to output. Review and update quarterly. Owner: IT Manager. This also feeds directly into the vendor risk process under CC9.

CC7 — System Operations

CC7.1 — System MonitoringGap: **Partial** Risk: **High** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
Crestline needs to actively monitor its production environment for anomalous activity — unauthorized access attempts, unusual data transfers, system errors. Without monitoring, incidents go undetected, and auditors have no evidence that operations were stable during the audit period.	AWS CloudWatch is configured but alert thresholds are not defined. Logs are being collected but not reviewed on any defined schedule. No SIEM or log aggregation tool is in use. No alerting for failed login attempts, privilege escalation, or unusual API activity is configured.	Configure CloudWatch alarms for: failed login attempts (threshold: 5 in 10 minutes), privilege escalation events, unusual API call volumes, and cost anomalies. Enable AWS GuardDuty for threat detection. Establish a weekly log review process with a documented review log (who reviewed, date, findings). A lightweight SIEM (AWS Security Hub, Datadog, or Splunk Free) is recommended for centralized visibility. Document a System Monitoring Policy. Owner: IT Manager.

CC7.2 — Change ManagementGap: **Non-Compliant** Risk: **High** Timeline: **30 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
Changes to Crestline's production systems — code deployments, configuration changes, infrastructure updates — should follow a formal process with review, approval, testing, and rollback planning. Undocumented changes are a primary source of outages and audit failures.	FINDING: Developers push changes directly to production without a formal review or approval process. No change request tickets are created. No rollback procedures are documented. Testing requirements prior to production deployment are undefined. Deployments are tracked only in Git commit logs, which are not consistently reviewed by anyone other than the committing developer.	Implement a formal Change Management Policy requiring: (1) all production changes initiated via a change request ticket (Jira or equivalent), (2) peer code review and approval before merge to main branch (enforce via GitHub branch protection rules), (3) testing in a non-production environment prior to deployment, (4) rollback procedure documented for each significant change, (5) post-deployment validation. Emergency change process should be defined for critical fixes with retroactive documentation required within 24 hours. Owner: VP of Engineering; enforced at repository level.

CC7.3 — Incident ResponseGap: **Non-Compliant** Risk: **High** Timeline: **30 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
If a security incident occurs — a breach, ransomware attack, data leak, or system compromise — Crestline needs a documented plan for how to respond. Without one, the response will be chaotic, slow, and likely to make things worse. Auditors require evidence that a plan exists and has been tested.	FINDING: No incident response plan exists in any form. There is no documented escalation path, no defined roles or responsibilities, no communication protocol, and no criteria for when an event is classified as a security incident versus a routine IT issue. If Crestline experienced a ransomware event or data breach today, response would be entirely improvised.	Draft and execute an Incident Response Plan (IRP) covering: (1) incident classification criteria (Severity 1–4 definitions), (2) response team roles (Incident Commander, Technical Lead, Communications Lead, Legal/Compliance), (3) escalation thresholds and contact list (internal + legal counsel + cyber insurance carrier), (4) containment and eradication procedures by incident type, (5) customer notification requirements and breach notification obligations under applicable law, (6) post-incident review process. Conduct a tabletop exercise within 90 days of IRP completion. Owner: IT Manager + CEO as executive sponsor.

CC7.4 — Incident Classification and ResponseGap: **Non-Compliant** Risk: **High** Timeline: **30 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Not every system anomaly is an incident, and not every incident has the same severity. Crestline needs a framework for classifying events, prioritizing response, and escalating appropriately based on the severity and type of issue detected.	No incident classification framework exists. When IT issues arise, they are addressed ad hoc based on who is available and how loud the complaint is. There is no formal mechanism for distinguishing between a routine service disruption and a potential security event requiring legal notification.	Develop an incident severity classification matrix as part of the IRP (see CC7.3). Define Severity 1 (active breach or data exfiltration), Severity 2 (confirmed security incident, contained), Severity 3 (suspected incident under investigation), Severity 4 (anomaly, no confirmed threat). Each severity level should have defined response SLAs, escalation requirements, and documentation standards. Owner: IT Manager.

CC7.5 — Anomaly and Threat DetectionGap: **Partial** Risk: **Medium** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Beyond reactive monitoring, Crestline should have mechanisms to proactively detect threats before they become incidents — unusual login patterns, unauthorized data access attempts, suspicious API calls. Early detection dramatically reduces breach impact.	No threat detection tooling beyond AWS-native logging. CloudTrail is enabled but alerts are not configured. No user and entity behavior analytics (UEBA) in place. No dark web monitoring or external threat intelligence feed subscribed to.	Enable AWS GuardDuty (cost-effective, native to existing AWS environment) for automated threat detection. Configure SNS notifications for GuardDuty high-severity findings to route to IT Manager email and an on-call Slack channel. Review GuardDuty findings weekly. Consider integrating with AWS Security Hub for a consolidated findings dashboard. Owner: IT Manager.

CC7.6 — Backup and Recovery OperationsGap: **Partial** Risk: **Medium** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Crestline's client data must be backed up regularly and those backups must be tested to confirm they can actually be restored. A backup that has never been tested is not a backup — it's a hope.	AWS RDS automated backups are enabled with a 7-day retention period. S3 versioning is enabled on primary data buckets. However, no backup restoration test has ever been performed. No defined RTO (Recovery Time Objective) or RPO (Recovery Point Objective) targets exist. Backup configuration has not been reviewed since initial AWS setup.	Define RTO and RPO targets for each critical system (suggested: RTO 4 hours, RPO 1 hour for production payroll system). Conduct a full backup restoration test in a non-production environment and document the results. Schedule restoration tests semi-annually. Review and validate backup configurations against defined RPO targets. Document in a Backup and Recovery Policy. Owner: IT Manager.

CC7.7 — Security Vulnerability ManagementGap: **Non-Compliant** Risk: **High** Timeline: **30 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Crestline should regularly scan its systems for known security vulnerabilities and have a process for prioritizing and remediating them. Unpatched systems are among the most common entry points for attackers.	No formal vulnerability scanning program exists. AWS Inspector has not been enabled. OS and application patching is performed reactively when updates are noticed, not on a defined schedule. No patch management policy or SLA for critical vulnerability remediation exists.	Enable AWS Inspector for automated vulnerability scanning of EC2 instances and container images. Establish a Patch Management Policy defining: Critical patches applied within 72 hours, High patches within 7 days, Medium within 30 days. Configure automatic OS security updates where possible. Conduct an initial vulnerability scan and remediate all Critical findings within 30 days. Document scan results and remediation actions monthly. Owner: IT Manager.

CC9 — Risk Mitigation

CC9.1 — Business Continuity and Disaster RecoveryGap: **Non-Compliant** Risk: **Medium** Timeline: **90 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
If something goes seriously wrong — a prolonged AWS outage, a ransomware attack that takes down production systems, a critical data loss event — Crestline needs a documented plan for how the business continues to operate and how quickly systems can be restored. Enterprise clients will ask for this during due diligence.	FINDING: No Business Continuity Plan (BCP) or Disaster Recovery Plan (DRP) exists in any documented form. RTO and RPO targets have not been defined. Backup restoration has never been tested (see CC7.6). If Crestline's primary AWS region experienced a multi-day outage, there is no documented procedure for recovery, no secondary region failover, and no communication plan for affected clients.	Develop a Business Continuity and Disaster Recovery Plan covering: (1) risk scenarios and impact analysis, (2) defined RTO/RPO per system, (3) AWS multi-AZ configuration review and cross-region backup strategy, (4) manual operating procedures for critical business functions during system downtime, (5) client communication templates for outage scenarios, (6) annual BCP/DRP test requirement. The plan should be approved by the CEO and reviewed annually. Owner: IT Manager + CEO.

CC9.2 — Vendor and Third-Party Risk ManagementGap: **Non-Compliant** Risk: **High** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
Crestline's clients are trusting it with payroll and HR data. If that data flows through a third-party vendor, Crestline is responsible for ensuring that vendor meets appropriate security standards. This means reviewing vendor security posture, requiring data protection terms in contracts, and maintaining an ongoing vendor oversight process.	FINDING: Crestline uses 6 third-party SaaS tools that process or have access to client payroll and HR data. Review of existing vendor contracts revealed that none include data security requirements, breach notification obligations, or data processing terms. Only 2 of the 6 vendors have been reviewed in the past year — the remaining 4 have had no security assessment since initial onboarding. No vendor risk register exists.	Immediately: Build a vendor risk register documenting all vendors with access to client data, including: vendor name, data type accessed, contract renewal date, last security review date, SOC 2 or ISO 27001 status. Within 60 days: Require execution of a Data Processing Agreement (DPA) or security addendum with each of the 6 vendors. Minimum requirements: encryption standards, breach notification within 72 hours, right to audit, data deletion upon contract termination. Ongoing: Annual vendor security review for all Tier 1 vendors (those with access to client data). Owner: IT Manager + Legal/Contracts.

CC9.3 — Risk Identification and AssessmentGap: **Non-Compliant** Risk: **Medium** Timeline: **60 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDIATION REQUIRED
SOC 2 requires that Crestline have a formal process for identifying and assessing risks to its systems and data — not just reacting to them as they arise. This means a documented risk register and a repeatable risk assessment methodology.	No formal risk register exists. No documented risk assessment methodology has been applied. Risk identification is ad hoc and based on individual judgment rather than structured analysis. The findings in this assessment represent the first structured risk identification exercise Crestline has undergone.	Develop an Information Security Risk Register using a standardized format: risk description, likelihood (1-5), impact (1-5), inherent risk score, current controls, residual risk score, risk owner, and mitigation plan. Populate with findings from this assessment as the initial baseline. Conduct formal risk assessment annually and following any significant change to the environment. Owner: IT Manager; executive review by CEO annually.

CC9.4 — Insurance and Risk TransferGap: **Partial** Risk: **Medium** Timeline: **90 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Part of managing risk is transferring some of it. Crestline should carry appropriate cyber liability insurance to cover costs associated with data breaches, ransomware events, regulatory fines, and client notification expenses. Enterprise clients increasingly verify this.	Crestline carries general commercial liability insurance but cyber liability coverage has not been verified as part of this assessment. No cyber insurance policy details were provided for review. Cyber insurance carriers typically require MFA, incident response plans, and backup procedures as underwriting requirements — all of which are currently gaps.	Verify current cyber liability coverage and confirm it is adequate for a business processing payroll data (minimum \$1M recommended at current scale). Remediate MFA and IRP gaps (CC6.1, CC7.3) first — these are underwriting requirements and may reduce premiums. Obtain cyber insurance binder as an audit evidence document. Owner: CFO + Legal.

CC9.5 — Security Awareness and TrainingGap: **Non-Compliant** Risk: **Medium** Timeline: **90 Days**

CONTROL OBJECTIVE	CURRENT STATE AT CRESTLINE	REMEDATION REQUIRED
Crestline employees are the last line of defense against phishing, social engineering, and accidental data exposure. A formal security awareness training program ensures employees know what threats look like, how to report them, and what their responsibilities are.	No formal security awareness training program exists. New employees receive no security-specific onboarding content. No phishing simulation has been conducted. Acceptable use and data handling expectations are not documented in any policy that employees have acknowledged.	Implement an annual security awareness training requirement for all employees. Platforms like KnowBe4, Proofpoint Security Awareness, or Curricula are cost-effective options at Crestline's size. Training should cover: phishing recognition, password hygiene, data handling, acceptable use, and incident reporting. Require employee acknowledgment of an Acceptable Use Policy (AUP) at onboarding and annually thereafter. Conduct quarterly phishing simulations. Track completion rates and document for audit evidence. Owner: HR + IT Manager.

SECTION 3: FINDINGS SUMMARY

The following table consolidates all control gaps identified during the assessment, sorted by risk rating. This is the section a reader skims to understand the overall risk posture before reviewing the full control assessment. Findings with a gap rating of 'Compliant' are excluded — only gaps are reflected here.

REF	CONTROL NAME	GAP RATING	RISK	TIMELINE	KEY FINDING
CC6.1	Logical Access Security	Non-Compliant	Critical	30 Days	The IT manager and two senior engineers access the production database and payroll system using only username and password combinations. No MFA is enforced. ...
CC6.3	User Access Review and Termination	Non-Compliant	Critical	30 Days	FINDING: During access log review, 7 active user accounts were identified belonging to former employees who departed 8 to 18 months ago. Three of these accou...
CC6.5	Logical Access Removal	Non-Compliant	Critical	30 Days	No documented deprovisioning procedure exists. Offboarding is handled informally between HR and the IT manager. Timing of access removal is inconsistent and ...
CC6.2	User Access Provisioning	Non-Compliant	High	30 Days	No formal onboarding access provisioning workflow exists. Access is granted informally via Slack message or verbal request to the IT manager. No approval rec...
CC6.6	Logical Access Restrictions — External Connections	Partial	High	60 Days	Remote access to production systems is conducted via direct SSH connections and RDP sessions without VPN enforcement. Contractor access is granted on an ad-h...
CC6.8	Malware and Unauthorized Software Controls	Partial	High	60 Days	Endpoint detection and response (EDR) software is not consistently deployed across all workstations. Some employee laptops use Windows Defender only. No mobi...
CC7.1	System Monitoring	Partial	High	60 Days	AWS CloudWatch is configured but alert thresholds are not defined. Logs are being collected but not reviewed on any defined schedule. No SIEM or log aggregat...
CC7.2	Change Management	Non-Compliant	High	30 Days	FINDING: Developers push changes directly to production without a formal review or approval process. No change request tickets are created. No rollback proce...
CC7.3	Incident Response	Non-Compliant	High	30 Days	FINDING: No incident response plan exists in any form. There is no documented escalation path, no defined roles or responsibilities, no communication protoco...
CC7.4	Incident Classification and Response	Non-Compliant	High	30 Days	No incident classification framework exists. When IT issues arise, they are addressed ad hoc based on who is available and how loud the complaint is. There i...
CC7.7	Security Vulnerability Management	Non-Compliant	High	30 Days	No formal vulnerability scanning program exists. AWS Inspector has not been enabled. OS and application patching is performed reactively when updates are not...
CC9.2	Vendor and Third-Party Risk Management	Non-Compliant	High	60 Days	FINDING: Crestline uses 6 third-party SaaS tools that process or have access to client payroll and HR data. Review of existing vendor contracts revealed that...
CC6.4	Physical Access to Information Assets	Partial	Medium	60 Days	Crestline operates in a leased office space with keycard access to the main entrance. A server closet exists on-premises housing networking equipment. The cl...

CC6.7	Transmission and Movement of Information	Partial	Medium	60 Days	API communications use HTTPS/TLS 1.2+. Internal database connections use encrypted channels. However, no formal data classification policy exists, and some i...
CC6.9	Data Encryption at Rest	Partial	Medium	30 Days	AWS S3 buckets used for data storage have server-side encryption enabled (AES-256 via SSE-S3). RDS database instances have encryption at rest enabled. Howeve...
CC6.10	Inventory and Classification of Information Assets	Non-Compliant	Medium	60 Days	No formal asset inventory exists. The IT manager maintains an informal list of hardware in a personal spreadsheet, but it has not been updated in approximate...
CC7.5	Anomaly and Threat Detection	Partial	Medium	60 Days	No threat detection tooling beyond AWS-native logging. CloudTrail is enabled but alerts are not configured. No user and entity behavior analytics (UEBA) in p...
CC7.6	Backup and Recovery Operations	Partial	Medium	60 Days	AWS RDS automated backups are enabled with a 7-day retention period. S3 versioning is enabled on primary data buckets. However, no backup restoration test ha...
CC9.1	Business Continuity and Disaster Recovery	Non-Compliant	Medium	90 Days	FINDING: No Business Continuity Plan (BCP) or Disaster Recovery Plan (DRP) exists in any documented form. RTO and RPO targets have not been defined. Backup r...
CC9.3	Risk Identification and Assessment	Non-Compliant	Medium	60 Days	No formal risk register exists. No documented risk assessment methodology has been applied. Risk identification is ad hoc and based on individual judgment ra...
CC9.4	Insurance and Risk Transfer	Partial	Medium	90 Days	Crestline carries general commercial liability insurance but cyber liability coverage has not been verified as part of this assessment. No cyber insurance po...
CC9.5	Security Awareness and Training	Non-Compliant	Medium	90 Days	No formal security awareness training program exists. New employees receive no security-specific onboarding content. No phishing simulation has been conducte...

Critical Findings: Detailed Narrative

Finding 1: Privileged Account MFA and Orphaned Account Access

Mapped to: CC6.1 / CC6.3 / CC6.5

During access log review, 7 active user accounts were identified belonging to former employees. Three of these accounts have not had a login attempt in over 12 months but remain active with read/write access to the production payroll processing system. The longest-standing orphaned account belongs to a former senior engineer who departed 18 months ago. This account retains database administrator permissions that were never revoked.

Compounding this, the IT manager and two current senior engineers access the production database and payroll system with username and password only. No multi-factor authentication is enforced. This means that if any of these credentials were compromised via phishing or credential stuffing, an attacker would have immediate, authenticated access to systems containing payroll data for every one of Crestline's small business clients.

These two issues together represent the highest-risk finding in this assessment. A formal auditor reviewing access logs would flag both on day one.

Finding 2: Absence of Incident Response Planning

Mapped to: CC7.3 / CC7.4

There is no documented incident response plan at Crestline in any form. This was confirmed through interviews with the IT manager and a review of internal documentation. No escalation paths exist. No roles have been defined. No communication templates have been prepared. No criteria distinguish a routine system issue from a security incident requiring legal notification.

The practical consequence is that if Crestline experienced a data breach involving client payroll information today, response decisions would be made entirely in real time, under pressure, by people who have not rehearsed the scenario. Many states require breach notification within 30, 45, or 72 hours depending on the type of data affected. Without a plan, Crestline is likely to miss those windows, increasing regulatory and legal exposure.

This is a Hard Stop finding for SOC 2 Type II. Auditors evaluating CC7 will require documented evidence that an IRP exists and has been tested.

SECTION 4: MANAGEMENT LETTER

June 27, 2026

To the Leadership of Crestline Technology Partners:

Engagement Scope

At the request of Crestline Technology Partners management, an independent SOC 2 Type II readiness assessment was conducted in June 2026. The assessment evaluated 22 controls across three categories of the AICPA Trust Services Criteria (2017, with 2022 points of focus): CC6 (Logical and Physical Access Controls), CC7 (System Operations), and CC9 (Risk Mitigation). The scope was limited to Crestline's production SaaS environment and associated operational processes. AWS infrastructure security was reviewed at the application and configuration layer; physical data center security is covered under AWS's own SOC 2 attestation and is out of scope for this assessment.

Assessment Methodology

The assessment was conducted through four methods: (1) documentation review — examination of existing policies, procedures, configuration records, and contracts; (2) stakeholder interviews with the IT manager and selected engineering staff; (3) system configuration inspection of AWS environment settings, access control configurations, and logging infrastructure; and (4) access log analysis to identify active accounts, access patterns, and anomalies. No penetration testing was conducted as part of this engagement.

Summary of Findings

The assessment identified 14 control gaps across the three TSC categories reviewed. By severity: 3 Critical findings, 6 High findings, and 5 Medium findings. 8 controls were assessed as compliant or partially compliant with only minor gaps. Critical findings include: (1) orphaned accounts with active access to production payroll systems, (2) absence of multi-factor authentication on privileged accounts, and (3) lack of a formal access termination process. High findings include an undocumented incident response process, informal change management with direct-to-production deployments, and vendor contracts that do not include security or data handling requirements. Medium findings include the absence of a business continuity/disaster recovery plan, a formal risk register, and a security awareness training program.

Readiness Opinion

Based on the findings of this assessment, it is the opinion of the assessor that Crestline Technology Partners is NOT READY for a SOC 2 Type II audit engagement at this time.

This opinion is based on the presence of Critical findings that would be likely to result in a qualified audit opinion or audit suspension if a formal engagement were initiated today. Specifically, the combination of orphaned privileged accounts, the absence of MFA on production system access, and the complete absence of incident response documentation represent control deficiencies that auditors would treat as material weaknesses.

Path to Readiness

Crestline can achieve a clean SOC 2 Type II audit opinion within 12 months if remediation efforts begin immediately and are executed with appropriate rigor. The critical condition for audit readiness is that all Critical and High findings be remediated and that remediated controls operate without exception for a minimum of six months prior to the audit

observation period. The recommended approach is detailed in Section 5 (12-Month Remediation Roadmap) of this report.

Management is encouraged to treat this assessment not as a compliance exercise, but as a business enablement effort. The enterprise contract currently contingent on SOC 2 completion is unlikely to be the last client to make this requirement. Building a documented security program now creates durable value across the client development pipeline.

Prepared by:

Maximilian Rivera

GRC Analyst | Independent Assessment

June 27, 2026

This assessment is prepared for portfolio demonstration purposes and does not constitute a formal audit opinion. It is intended to demonstrate applied GRC methodology and documentation capabilities.

SECTION 5: 12-MONTH REMEDIATION ROADMAP

The roadmap below reflects the recommended sequencing of remediation activities across three phases. Phase 1 must be completed before a formal audit engagement begins. Phase 3 represents the evidence-generation period required for SOC 2 Type II — controls must operate consistently and be documented for the full observation window.

PHASE 1 Days 1–90: Fix Critical and High Findings

Phase Objective: Close all Critical and High findings. These are the controls that would cause an auditor to halt or qualify an engagement. Nothing in Phase 2 or 3 matters if these remain open.

TIMING	MILESTONE / DELIVERABLE
Days 1–14	Disable all orphaned accounts identified in access log review (CC6.3, CC6.5)
Days 1–14	Enroll all privileged accounts in MFA — IT manager, senior engineers, database access accounts (CC6.1)
Days 1–30	Draft and execute Incident Response Plan with defined severity classifications, roles, and escalation paths (CC7.3, CC7.4)
Days 1–30	Implement formal Access Request and Offboarding workflow with documented approvals (CC6.2, CC6.5)
Days 15–30	Implement Change Management Policy with branch protection rules and peer review requirements (CC7.2)
Days 30–45	Enable AWS Inspector for vulnerability scanning; remediate Critical CVEs (CC7.7)
Days 30–60	Require VPN + MFA for all remote and contractor access; implement network segmentation (CC6.6)
Days 45–60	Execute DPAs or security addenda with all 6 vendors accessing client data (CC9.2)
Days 60–90	Complete vendor risk register with security review status for all Tier 1 vendors (CC9.2)
Days 60–90	Configure CloudWatch alerting and enable GuardDuty for threat detection (CC7.1, CC7.5)
Days 75–90	Deploy EDR to all company-managed endpoints; implement MDM policy (CC6.8)
Day 90	Conduct first access certification review — system owners certify all active accounts (CC6.3)

PHASE 2 Days 91–180: Build Program Infrastructure

Phase Objective: Establish the policy library, training programs, and operational processes that support sustained control operation. Phase 2 builds the infrastructure that generates audit evidence in Phase 3.

TIMING	MILESTONE / DELIVERABLE
Days 91–120	Complete Information Security Policy library: Access Management, Acceptable Use, Data Classification, Encryption, Patch Management, Physical Security (all TSC categories)
Days 91–120	Require all employees to read and acknowledge Acceptable Use Policy (CC9.5)
Days 91–120	Conduct tabletop incident response exercise; document results and gaps (CC7.3)
Days 105–135	Implement security awareness training platform; complete first all-employee training cycle (CC9.5)
Days 105–150	Develop and document Business Continuity and Disaster Recovery Plan with defined RTO/RPO (CC9.1)
Days 120–150	Conduct first BCP/DRP tabletop exercise (CC9.1)
Days 120–150	Complete backup restoration test in non-production environment; document results (CC7.6)
Days 120–150	Complete first formal vulnerability assessment; remediate all High and Critical findings (CC7.7)
Days 135–165	Build Information Security Risk Register; populate with all findings from this assessment (CC9.3)

Days 150–180	Verify cyber liability insurance coverage; obtain binder for audit evidence file (CC9.4)
Days 165–180	Complete first quarterly phishing simulation; document results and remediation for failures (CC9.5)
Day 180	Mid-point readiness checkpoint: review all Phase 1 controls for sustained operation; identify any regression

PHASE 3 Days 181–365: Operate Controls and Generate Evidence

Phase Objective: SOC 2 Type II requires that controls operate without exception over the observation period — typically 6 to 12 months. Phase 3 is about consistency: running the processes built in Phases 1 and 2, capturing evidence at every step, and preparing the audit evidence package. The formal audit can begin no earlier than Day 181 at the absolute minimum, and Day 270+ is more realistic for a clean opinion.

TIMING	MILESTONE / DELIVERABLE
Monthly	Access certification review — system owners certify active accounts; retain records (CC6.3)
Monthly	Security monitoring review — IT Manager reviews GuardDuty findings, CloudWatch alerts, access logs; document outcomes (CC7.1)
Monthly	Patch compliance review — verify all Critical/High patches applied within SLA; document exceptions (CC7.7)
Quarterly	Change Management review — audit sample of change tickets for proper approvals, testing, rollback documentation (CC7.2)
Quarterly	Vendor risk review — update vendor register; verify any new vendors are assessed before data access granted (CC9.2)
Quarterly	Phishing simulation — conduct simulation; document results; provide targeted training to failures (CC9.5)
Day 270	Pre-audit readiness review — formal internal assessment of all 22 controls; identify any gaps before engaging auditors
Day 300	Engage SOC 2 auditor — request for proposal, auditor selection, scope confirmation, kickoff
Day 310	Audit evidence package preparation — organize artifacts by TSC category; verify completeness
Day 330	Auditor fieldwork period — respond to evidence requests; provide system demos
Day 365	Target: Clean SOC 2 Type II audit report issued

A Note on Evidence Quality

SOC 2 Type II auditors do not take your word for it. Every control must be supported by contemporaneous evidence — screenshots, exported logs, signed documents, ticketing system records, training completion certificates. The documentation habit needs to start on Day 1. If a control is operating but the evidence was not captured, it did not happen from an audit perspective. Build documentation discipline into every process built in Phase 1, not as an afterthought in Phase 3.